
PASSWORD AND AUTHENTICATION POLICY REVIEW

Alderbridge Financial Services Ltd

A Structured Gap Review Against NIST, CIS and ISO 27001 Benchmarks

Prepared by: Reward Oladejo-Olagboye

Report date: 10 August 2026

Standards Referenced: NIST SP 800-63B, CIS Controls v8, ISO/IEC 27001:2022

Classification: Confidential, Internal and Board Distribution Only

Note: Alderbridge Financial Services Ltd is a fictional organisation created for the purpose of demonstrating a structured policy review methodology.

Document Control

Field	Detail
Document Title	Password and Authentication Policy Review
Organisation	Alderbridge Financial Services Ltd (fictional)
Version	1.0
Author	Reward Oladejo-Olagboye
Date	29 July 2026
Standards Referenced	NIST SP 800-63B, CIS Controls v8, ISO/IEC 27001:2022 Annex A
Classification	Confidential
Related Documents	Cybersecurity Risk Register and Assessment Report (Risk R06)

Table of Contents

For the Board: What You Need to Know 4

1. Purpose and Scope 5

2. Review Methodology..... 5

3. Policy Under Review 6

4. Structured Review Questions and Findings..... 7

5. Gap Analysis 8

6. Recommended Redline Summary 9

7. Conclusion 9

Appendix: Reference Standards Consulted 10

For the Board: What You Need to Know

We reviewed our current password and login rules against recognised international good practice, to check whether they still hold up.

The short answer is that our rules are reasonable but out of date. They were built around ideas that used to be considered best practice, such as forcing everyone to change their password every 90 days, but current expert guidance has moved on from this approach because it does not meaningfully improve security and often leads to weaker, more predictable passwords.

The two most important gaps are:

- Extra login verification, beyond just a password, is only required when staff work remotely. It should apply consistently, especially for anyone with access to sensitive systems, regardless of where they are working from.
- New passwords are not checked against lists of passwords already known to have been leaked elsewhere. This is a quick, low-cost check that meaningfully reduces risk.

None of the recommended changes require rebuilding the policy from scratch. Ten specific, practical updates have been identified, and none of them are complex or costly to put in place.

1. Purpose and Scope

This document reviews Alderbridge Financial Services Ltd's existing Password and Authentication Policy against current industry guidance, to determine whether the policy remains fit for purpose and to identify any gaps that increase the organisation's exposure to credential based attacks.

This review covers the password and authentication requirements applicable to staff, contractors and third parties accessing Alderbridge systems. It does not extend to physical access control, building security, or authentication mechanisms used solely by customers on public facing services.

This review was prompted in part by a related finding in the organisation's cybersecurity risk register, which identified inconsistent multi factor authentication enforcement across privileged accounts as a high priority risk.

2. Review Methodology

The existing policy was assessed clause by clause against a structured set of review questions, each derived from recognised industry standards and control frameworks. Three reference sources were used to benchmark the policy:

- NIST Special Publication 800-63B, Digital Identity Guidelines: widely regarded modern guidance on authentication, which has shifted industry thinking away from forced periodic password rotation and complex composition rules, toward longer passphrases, screening against known breached credentials, and risk based authentication decisions.
- CIS Controls version 8, Control 5 (Account Management) and Control 6 (Access Control Management): practical safeguards covering account lifecycle management, unique credentials, and the governance of privileged access.
- ISO/IEC 27001:2022 Annex A, controls A.5.17 (Authentication Information) and A.8.5 (Secure Authentication): requirements for organisations to manage authentication information through a formal lifecycle and to enforce secure authentication procedures across their environment.

Each review question was RAG rated, Red, Amber or Green, based on the current policy text, and each identified gap was assigned the same Red, Amber, Green rating for severity and paired with a specific recommendation. Red indicates the requirement is not met and carries meaningful risk, Amber indicates partial coverage, and Green indicates the requirement is fully met.

3. Policy Under Review

The following is the current Password and Authentication Policy in effect at Alderbridge Financial Services Ltd, version 1.0, as submitted for this review.

3.1 Purpose

This policy defines the minimum requirements for creating, managing and protecting passwords used to access Alderbridge Financial Services Ltd systems and data.

3.2 Scope

This policy applies to all employees, contractors and third parties accessing Alderbridge systems using a username and password.

3.3 Policy Statements

1. Passwords must be a minimum of 8 characters in length.
2. Passwords must contain at least one uppercase letter, one lowercase letter, one number and one special character.
3. Passwords must be changed every 90 days.
4. Users may not reuse any of their previous 5 passwords.
5. Accounts will be locked after 5 consecutive failed login attempts.
6. Multi factor authentication is required for staff accessing company systems remotely.
7. Passwords must not be shared with colleagues or written down in an unsecured location.
8. Users are responsible for maintaining the confidentiality of their own credentials.

4. Structured Review Questions and Findings

Eleven questions were used to assess the policy against the reference standards set out in Section 2. Each is RAG rated below.

No.	Review Question	RAG Rating	Notes
1	Does the policy define a minimum and maximum password length aligned to current guidance?	MEDIUM	Minimum length is defined at 8 characters. No maximum is set and passphrases are not encouraged.
2	Does the policy require multi factor authentication for all account types?	HIGH	MFA is required for remote access only. On premises and privileged sessions are not covered.
3	Does the policy require passwords to be screened against known breached credential lists?	HIGH	No screening mechanism is referenced anywhere in the policy.
4	Does the policy separate requirements for standard user accounts from privileged or administrative accounts?	HIGH	All account types are subject to the same uniform requirements.
5	Does the policy address service, system or application account credentials?	HIGH	The policy scope covers user accounts only, with no mention of non-human accounts.
6	Does the policy prohibit shared accounts and require default vendor credentials to be changed?	MEDIUM	Sharing is discouraged informally but not explicitly prohibited, and default credentials are not addressed.
7	Does the policy base password rotation on risk or compromise indicators rather than a fixed calendar interval?	HIGH	Rotation is fixed at 90 days regardless of any compromise indicator.
8	Does the policy reference or recommend an approved password manager?	HIGH	No guidance is provided on credential storage tools.
9	Does the policy define an account lockout duration and a verified recovery process?	MEDIUM	A lockout threshold is defined, but no duration or recovery process is specified.
10	Does the policy assign a named owner and a defined review cycle?	HIGH	No ownership or review cadence is stated anywhere in the document.
11	Does the policy align with a recognised external standard or framework?	MEDIUM	The policy reflects a dated composition and rotation model rather than current NIST guidance.

5. Gap Analysis

Ten gaps were identified through the structured review. Each is RAG rated and paired with a specific, actionable recommendation.

ID	Area	Gap Description	Reference	Severity	Recommendation
G01	Password Rotation	Fixed 90 day rotation is required regardless of compromise indicators, which can encourage weak, incremental password changes rather than genuinely stronger credentials.	NIST SP 800-63B	MEDIUM	Replace the fixed rotation requirement with rotation triggered by evidence of compromise, supported by ongoing credential exposure monitoring.
G02	Multi Factor Authentication	MFA is not mandated for all account types. Enforcement is currently limited to remote access, leaving on premises privileged sessions uncovered.	CIS Controls v8, Control 6	HIGH	Extend mandatory MFA to all privileged and administrative accounts regardless of connection origin, and to all remote and cloud based access.
G03	Minimum Password Length	Minimum length is set at 8 characters with no defined maximum and no encouragement toward longer passphrases.	NIST SP 800-63B	MEDIUM	Increase minimum length guidance to at least 12 characters, support lengths up to 64 characters, and encourage passphrase style passwords.
G04	Compromised Password Screening	New passwords are not screened against known breached password lists at the point of creation or change.	NIST SP 800-63B	HIGH	Implement automated screening of new passwords against a breached password database before they are accepted.
G05	Service and System Accounts	The policy scope covers user accounts only, with no distinct requirements for service, system or application account credentials.	CIS Controls v8, Control 5	MEDIUM	Introduce a dedicated section covering service account credential management, including vaulting and clear rotation ownership.
G06	Password Manager Guidance	The policy is silent on the use of approved password managers, leaving staff to rely on memory or informal storage methods.	ISO/IEC 27001:2022 Annex A.5.17	LOW	Recommend and provide an approved enterprise password manager for staff use.
G07	Account Lockout and Recovery	Lockout after 5 failed attempts is defined, but the policy does not specify a lockout duration or a verified recovery process.	NIST SP 800-63B	LOW	Define a specific lockout duration and a verified, auditable account recovery process.
G08	Shared and Default Credentials	The policy does not explicitly prohibit shared accounts or address default vendor credentials on newly deployed systems.	ISO/IEC 27001:2022 Annex A.8.5	HIGH	Explicitly prohibit shared credentials and require default vendor passwords to be changed before any system enters production use.
G09	Privileged Account Differentiation	The same requirements apply uniformly to standard and privileged accounts, with no elevated controls for administrative access.	CIS Controls v8, Control 5	HIGH	Introduce elevated requirements for privileged accounts, including shorter session timeouts and mandatory MFA without exception.
G10	Policy Ownership and Review Cadence	The policy does not specify how frequently it should be reviewed or who is accountable for that review.	ISO/IEC 27001:2022 Annex A.5.17	LOW	Assign a named policy owner and mandate a documented annual review cycle.

6. Recommended Redline Summary

The table below summarises how the core policy statements should change as a direct result of this review.

- Replace the fixed 90 day rotation requirement with rotation triggered by evidence of compromise (G01).
- Extend mandatory multi factor authentication to all privileged, administrative and on premises sessions, not remote access alone (G02, G09).
- Raise the minimum password length to 12 characters, permit up to 64 characters, and actively encourage passphrases (G03).
- Introduce automated screening of new passwords against known breached credential lists (G04).
- Add a dedicated clause governing service, system and application account credentials (G05).
- Recommend and provide an approved enterprise password manager (G06).
- Define a specific account lockout duration and a verified recovery process (G07).
- Explicitly prohibit shared accounts and require default vendor credentials to be changed before production use (G08).
- Assign a named policy owner and mandate an annual review cycle (G10).

7. Conclusion

The current Password and Authentication Policy reflects an older composition and rotation based model that has largely been superseded by current industry guidance. While the policy is not without merit, particularly its account lockout threshold and remote access MFA requirement, it falls short in several areas that carry genuine operational risk, most notably the absence of universal multi factor authentication and the lack of any breached credential screening.

None of the identified gaps require a wholesale rewrite. Implementing the ten recommendations in this report would bring the policy substantially in line with NIST, CIS and ISO 27001 expectations, and would directly address the multi factor authentication risk already flagged in the organisation's cybersecurity risk register.

Appendix: Reference Standards Consulted

NIST SP 800-63B: Digital Identity Guidelines published by the National Institute of Standards and Technology, covering authentication and lifecycle management for digital credentials

CIS Controls v8: A prioritised set of safeguards published by the Center for Internet Security, referenced here for Control 5, Account Management, and Control 6, Access Control Management

ISO/IEC 27001:2022: The international standard for information security management systems, referenced here for Annex A controls A.5.17, Authentication Information, and A.8.5, Secure Authentication

This report is based on publicly available summaries of the standards named above and does not reproduce their text. It is intended to demonstrate a structured policy review methodology and does not constitute formal certification or compliance advice.